

FINAL PROJECT:

Designing a Cybersecurity Program for a FinTech Startup

NEU DAMG7350 (Spring 2026)

GROUP: Jennifer R Clark, Daniel Czajkowski, Ian Latta, Ziwei Song

Table of Contents

1. Introduction	2
2. System Architecture.....	3
2.1 System Architecture – Overview.....	4
2.1.1. Public Zone – Controlled Entry Point	4
2.1.2. Application Zone – Business Logic and Access Control	4
2.1.3. Data Zone – Sensitive Data and Audit Controls	5
2.1.4. Cross-Zone Security Principles.....	5
3. Assumptions	6
3.1 Organizational and Operational Assumptions	6
3.2 Technology and Infrastructure Assumptions	6
3.3 Security and Access Control Assumptions	6
3.4 Logging, Monitoring, and Compliance Assumptions	6
3.5 Threat Model and Incident Response Assumptions	7
3.6 Out-of-Scope Items	7
4. Risk Register	7
5. Threat Model (STRIDE).....	10
5.1 Spoofing (Authenticity)	10
5.2 Tampering (Integrity).....	11
5.3 Repudiation (Non-repudiation).....	11
5.4 Information Disclosure (Confidentiality)	11
5.5 Denial of Service (Availability).....	12
5.6 Elevation of Privilege (Authorization)	12
6. Identity and Access Management (IAM)	12
6.1 IAM Roles	12
6.2 Permissions and Least Privilege.....	12
6.3 Authentication and Authorization Flows	14
7. SIEM Monitoring Strategy	16
7.1 Data Ingestion Sources.....	16
7.2 Detection Use Case 1: Brute Force and Credential Stuffing.....	16

7.3 Detection Use Case 2: Unauthorized Internal Privilege Escalation	17
7.4 Detection Use Case 3: Abnormal Transaction Volume (Anomalous Activity).....	17
8. Incident Response Plan.....	18
8.1 Preparation	18
8.2 Identification.....	19
8.3 Containment	19
8.4 Eradication.....	19
8.5 Recovery	19
8.6 Lessons Learned	20
8.7 Playbook: Compromised IAM Credential.....	20
9. Conclusion	21
References	22
Appendix A – Authoring Credit & AI Statement.....	25

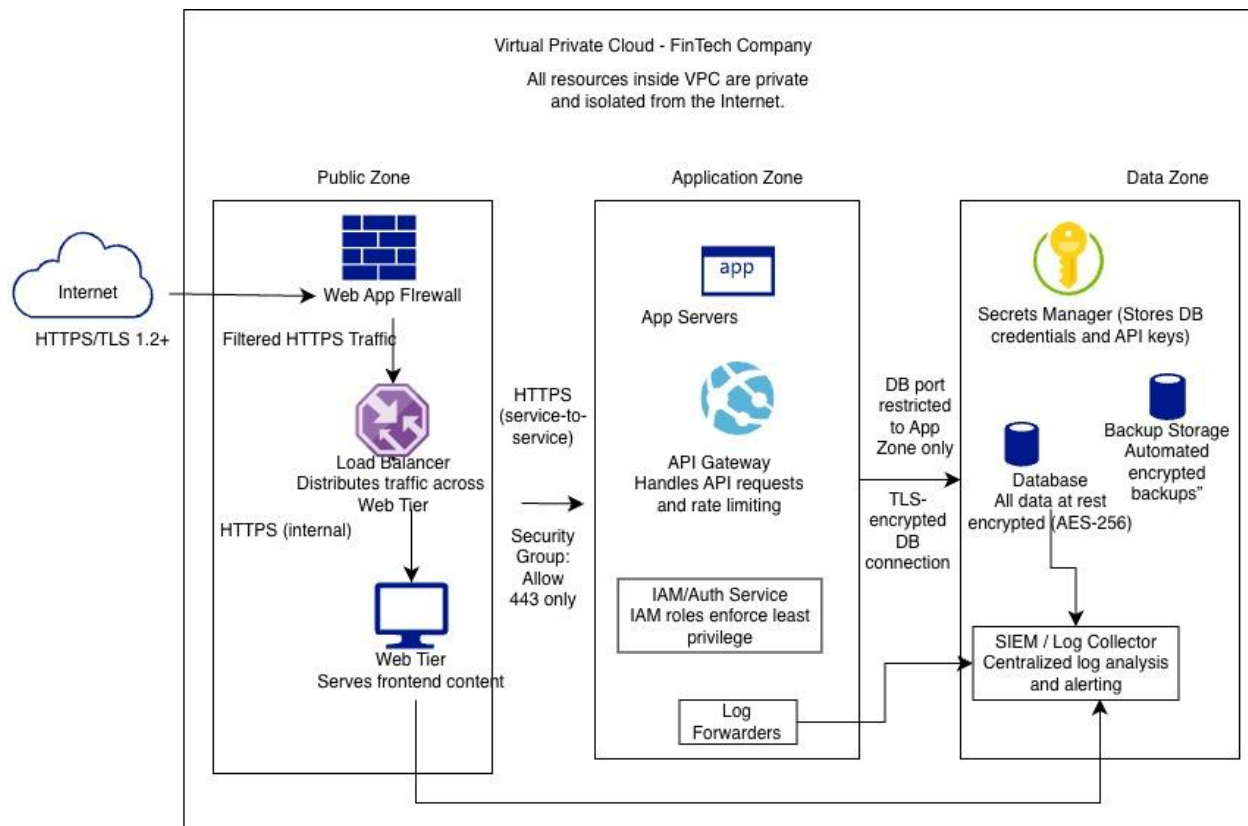
1. Introduction

FinTech startups that process financial transactions and store sensitive customer data face serious cyber threats, including credential attacks, insider misuse, and data breaches, any of which can result in financial losses, regulatory penalties, and erosion of customer trust. Regulatory frameworks such as PCI DSS, SOC 2, GDPR, and CCPA impose strict obligations on organizations that handle payment data and personally identifiable information, making compliance a prerequisite for market entry.

At the same time, the cloud-native infrastructure that gives startups speed and scalability also expands the attack surface, introducing risks around misconfigured services, overly permissive identity policies, and insufficient network segmentation. Designing security into the system from the outset is therefore a foundational business requirement, not merely a compliance exercise. This report presents a cybersecurity program for a fictional cloud-hosted FinTech startup, integrating principles from the CIA triad into a defense-in-depth architecture. The program covers secure system design, STRIDE threat modeling, a risk register, IAM least-privilege controls, SIEM monitoring with Splunk-style detection use cases, and an incident response plan aligned with NIST SP 800-61. Together, these components provide a practical blueprint that balances security rigor with the operational agility an early-stage company requires.

2. System Architecture

This architecture organizes the FinTech application into three security zones inside a Virtual Private Cloud (VPC). Each zone has a distinct purpose, and traffic between zones is tightly controlled. The design emphasizes isolation, least privilege, encrypted communication, and centralized monitoring—core requirements for systems handling financial data.



2.1 System Architecture – Overview

2.1.1. Public Zone – Controlled Entry Point

The Public Zone is the only Internet-facing layer. It receives external traffic, applies security controls, and forwards validated requests inward.

- **Web Application Firewall (WAF):** Blocks malicious patterns such as injection attempts and bot traffic.
- **Load Balancer:** Terminates TLS and distributes requests across the Web Tier.
- **Web Tier:** Serves frontend content only. It does not contain business logic or direct access to backend systems, reducing the impact of compromise.

This zone establishes a strict perimeter: only sanitized, encrypted traffic reaches the Application Zone.

2.1.2. Application Zone – Business Logic and Access Control

The Application Zone hosts core services and enforces authentication, authorization, and API governance. It is not directly reachable from the Internet.

- **Security Group (Port 443 Only):** Restricts traffic to HTTPS.
- **App Servers:** Execute business logic and coordinate backend interactions.
- **API Gateway:** Central point for routing, throttling, and request validation.
- **IAM/Auth Service:** Centralizes identity and access control.
- **Log Forwarders:** Send application logs to the SIEM.

This zone ensures only authenticated, validated requests reach sensitive systems.

2.1.3. Data Zone – Sensitive Data and Audit Controls

The Data Zone contains the most sensitive assets and applies the strictest access controls.

- **Database:** Stores financial and user data; encrypted at rest (AES-256) and accessed only via TLS.
- **DB Port Restriction:** Only App Servers may connect.
- **Secrets Manager:** Stores database credentials and API keys.
- **Backup Storage:** Provides automated, encrypted backups.
- **SIEM / Log Collector:** Aggregates logs from all zones for monitoring and audit.

This zone ensures sensitive data is accessible only through validated application paths.

2.1.4. Cross-Zone Security Principles

Several architectural choices apply across all zones:

- **Encryption in transit:** HTTPS/TLS or TLS-encrypted DB connections.
- **Encryption at rest:** Sensitive data is encrypted using AES-256.
- **Least privilege:** IAM roles and security groups restrict access.

- **Segmentation:** Clear boundaries limit lateral movement.
- **Centralized logging:** All zones forward logs to the SIEM.

3. Assumptions

These assumptions define the scope and operating conditions for the cybersecurity program and support the threat model, IAM design, SIEM strategy, and incident response plan.

3.1 Organizational and Operational Assumptions

- The company is an early-stage FinTech startup with a small engineering team and limited operational staff.
- The environment is hosted in a single Virtual Private Cloud (VPC).
- Personnel follow secure coding and deployment practices.
- A centralized code repository and CI/CD pipeline with access controls is already in place.

3.2 Technology and Infrastructure Assumptions

- All VPC resources are private by default and not Internet-accessible.
- Managed cloud services (Secrets Manager, SIEM, backup storage) are available.
- TLS 1.2+ is enforced for all communication.
- The system uses a three-tier architecture unless expanded later.

3.3 Security and Access Control Assumptions

- IAM roles are used for all service-to-service access; no hard-coded credentials exist.
- Least privilege is enforced at both network and identity layers.
- Administrative access requires MFA.
- No direct database access is permitted from external networks.

3.4 Logging, Monitoring, and Compliance Assumptions

- All logs are forwarded to the SIEM in near real time.

- Log retention meets regulatory expectations.
- The organization intends to pursue compliance frameworks relevant to FinTech (e.g., SOC 2, PCI DSS).

3.5 Threat Model and Incident Response Assumptions

- The threat model focuses on realistic risks for a cloud-hosted FinTech risks such as credential misuse, API abuse, data exfiltration, and misconfiguration.
- The incident response team has access to necessary cloud logs and forensic data.
- Third-party integrations follow their own security and compliance obligations.

3.6 Out-of-Scope Items

- Multiregional failover and advanced disaster recovery.
- Advanced security tooling (e.g., EDR, container scanning, DLP) is not included unless explicitly added later.

4. Risk Register

The following risk register identifies key security risks facing the FinTech startup's cloud-hosted environment. Each risk is assessed by likelihood and impact to produce an overall risk rating, with specific mitigations mapped to the system architecture described in Section 2. Ratings follow a qualitative scale (High, Medium, Low) based on the probability of occurrence and the severity of consequences to financial operations, customer trust, and regulatory standing.

ID	Risk Description	Likelihood	Impact	Rating	Proposed Mitigation
R-1	Credential Compromise via Brute Force or	High	High	High	Enforce MFA for all user accounts. Deploy rate-limiting and account

	Credential Stuffing. Attackers use automated tools to guess or replay stolen credentials against the login endpoint, leading to unauthorized account access and fraudulent transactions.				lockout policies at the WAF and API Gateway. Implement the SIEM brute-force detection use case (Section 7.2) to trigger automated alerts and temporary IP blocks after repeated failures.
R-2	Insider Privilege Escalation. A malicious or compromised insider exploits misconfigured IAM policies to escalate their own permissions, gaining unauthorized access to the production database or administrative controls.	Medium	High	High	Enforce least-privilege IAM roles (Section 6.2) with explicit deny policies. Implement Just-In-Time (JIT) access for elevated privileges. Monitor for unauthorized privilege changes via the SIEM escalation detection use case (Section 7.3). Require segregation of duties and peer approval for all IAM policy modifications.
R-3	Sensitive Data Exposure through API Vulnerability. An attacker exploits an Insecure Direct Object Reference (IDOR) or broken access control flaw in the API to access other customers' financial records, triggering regulatory reporting obligations under GDPR or CCPA.	Medium	High	High	Enforce object-level authorization checks at the API Gateway and application layer. Encrypt all data at rest with AES-256 and tokenize sensitive card data so raw values are never stored. Conduct regular penetration testing focused on OWASP API Security Top 10 vulnerabilities. Route all API traffic through the WAF for input validation.

R-4	Distributed Denial of Service (DDoS) against Transaction Gateway. A volumetric or application-layer DDoS attack overwhelms the Public Zone, rendering the transaction platform unavailable during peak hours and causing direct revenue loss and customer churn.	High	High	High	Deploy WAF with rate-limiting rules at the Public Zone boundary (Section 2.1.1). Configure elastic auto-scaling for the Load Balancer and Web Tier to absorb traffic spikes. Leverage the cloud provider's DDoS protection service. Establish an incident response playbook for availability events with defined escalation paths.
R-5	Exposed or Hard-Coded Secrets in Application Code. Database credentials, API keys, or encryption keys are accidentally committed to the code repository or left in configuration files, allowing an attacker who gains repository access to compromise backend systems.	Medium	High	Medium	Store all secrets in the centralized Secrets Manager within the Data Zone (Section 2.1.3). Enforce automatic credential rotation every 90 days (Section 6.3). Integrate pre-commit hooks and CI/CD pipeline scanning to detect and block secrets before they reach the repository. Prohibit hard-coded credentials via IAM policy (Section 6.2).
R-6	Transaction Tampering in Transit. An attacker performing a man-in-the-middle attack intercepts and	Low	High	Medium	Enforce TLS 1.3 for all inter-zone communication and Mutual TLS (mTLS) for service-to-service calls (Section 2.1.4). Implement digital

	modifies transaction payloads between zones, altering destination accounts or transfer amounts to redirect funds.				signatures on transaction payloads at the application layer so any modification invalidates the message. Log and alert on TLS handshake failures via the SIEM.
R-7	Insufficient Logging Leading to Undetected Breach. Gaps in log coverage or delayed log forwarding allow an attacker to operate within the environment undetected for an extended period, increasing the scope and cost of a breach.	Medium	Medium	Medium	Ensure all data sources identified in Section 7.1 (VPC Flow Logs, CloudTrail, application logs, WAF logs) are ingested into the SIEM in near-real time. Implement append-only, tamper-evident log storage. Configure alerts for log forwarding interruptions. Retain logs per regulatory requirements (1–7 years) as outlined in Section 3.4.

5. Threat Model (STRIDE)

To ensure the resilience of our startup’s architecture, the STRIDE framework was employed to identify and prioritize potential vulnerabilities. By analyzing the system through the lens of attacker goals—Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, and Elevation of Privilege—the design moves beyond reactive patching toward a "secure by design" posture. This analysis maps specific threats to our internal infrastructure components to ensure comprehensive coverage.

5.1 Spoofing (Authenticity)

An attacker may utilize credential stuffing or intercepted API session tokens to impersonate a customer or a backend microservice. Successful spoofing allows for unauthorized

peer-to-peer transfers and account takeovers. To mitigate this, the architecture must enforce Multi-Factor Authentication (MFA) for all users and Mutual TLS (mTLS) for internal service-to-service communication to ensure only verified services exchange data (Microsoft, 2024).

5.2 Tampering (Integrity)

A malicious actor could intercept a transaction request in transit to modify destination account numbers or amounts. Such tampering leads to direct capital loss and reconciliation failures. The system must protect all data in transit via TLS 1.3 and implement digital signatures for transaction payloads at the application layer, ensuring any unauthorized modification renders the packet invalid (Khan et al., 2017). The API Gateway validates these signatures before routing requests to the backend.

5.3 Repudiation (Non-repudiation)

A user might perform a high-value transfer and later dispute it, claiming their account was compromised. Without granular logs, the startup faces significant legal liability during "friendly fraud" disputes. Mitigation requires a centralized, append-only logging system where every transaction is tied to a cryptographically signed audit trail including hardware-backed device identifiers (Behbehani et al., 2022).

5.4 Information Disclosure (Confidentiality)

Attackers may exploit Insecure Direct Object Reference (IDOR) vulnerabilities in the Open Banking API to download private bank statements. Exposure of Personally Identifiable Information (PII) triggers mandatory reporting under GDPR and CCPA, resulting in catastrophic fines (Behbehani et al., 2022). A "Zero Trust" model will be adopted, encrypting data at rest (AES-256) and using tokenization to ensure raw card data is never stored. Segmentation will also be used so databases containing PII are isolated in a private subnet, accessible only via specific

service accounts.

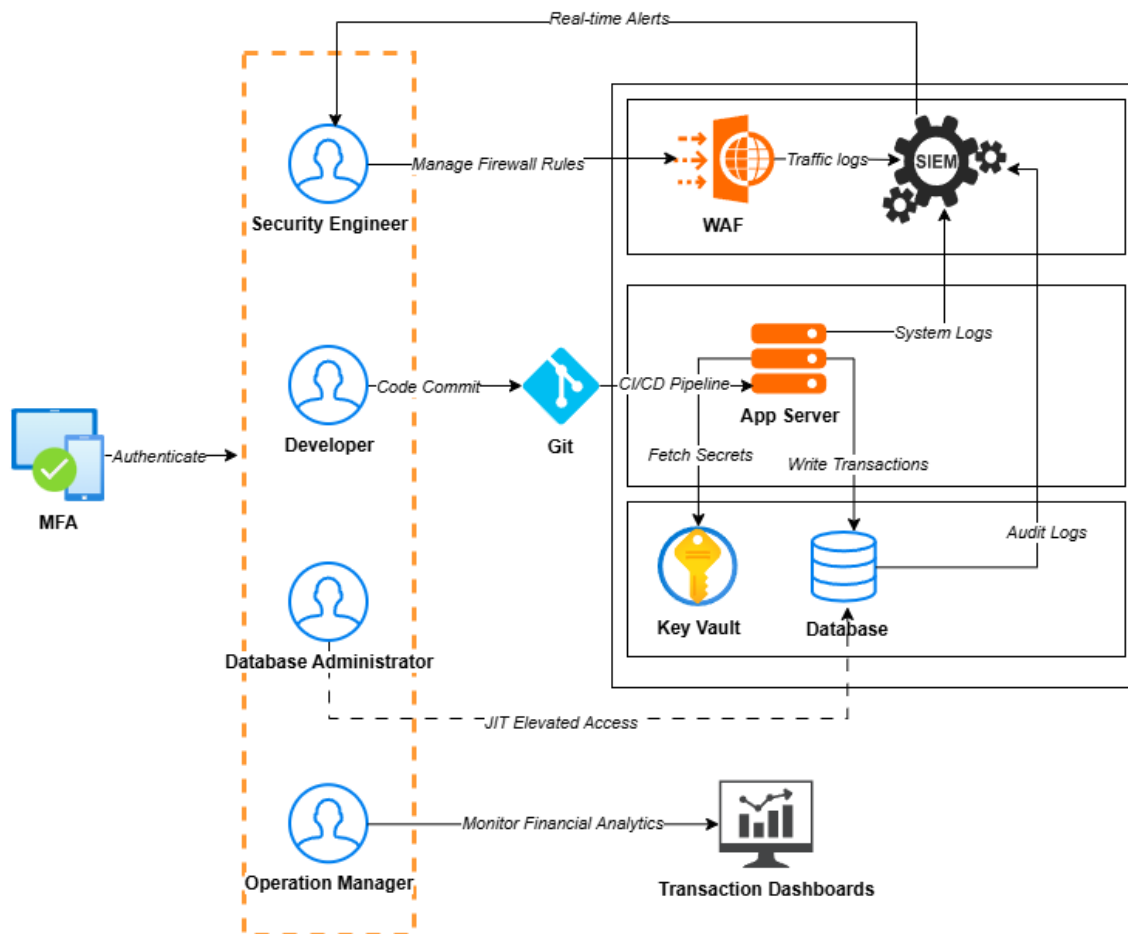
5.5 Denial of Service (Availability)

Volumetric DDoS attacks against the transaction gateway can prevent customers from accessing funds during peak hours, leading to immediate churn. The architecture will incorporate elastic load balancing and automated scaling to absorb traffic spikes. Deployment behind a specialized Web Application Firewall (WAF) with strict rate-limiting is essential to filter malicious traffic (Microsoft, 2024).

5.6 Elevation of Privilege (Authorization)

Internal threats involve employees exploiting "broken function level authorization" to gain administrative access to the master ledger. This allows for the illicit modification of balances or the bypassing of fraud triggers. The system will enforce the Principle of Least Privilege (PoLP) through Role-Based Access Control (RBAC) and require "Dual Control" (M-of-N authorization) for high-risk administrative actions (Khan et al., 2017).

6. Identity and Access Management (IAM)



6.1 IAM Roles

Role-Based Access Control (RBAC) is used to define IAM roles, with a clear distinction between Human Identities and Service Identities.

User Accounts: Developer, Security Engineer, Database Administrator, and Operation Manager.

Service Account: App Server.

6.2 Permissions and Least Privilege

Developer

- Allowed: Read/Write access to development and testing environments. Read, update, and merge code in version control systems such as Git.

- Denied: Access to the production environment and real customer data. Modification of CI/CD pipeline security checks.
- Justification: Developers need to build and test code but do not require access to live financial assets or sensitive customer information to perform their duties.

Security Engineer

- Allowed: Read-only access to all system logs and SIEM dashboards. Modify Web Application Firewall (WAF) and security rules. Manage incidents and alerts.
- Denied: Access to customer financial records. Modification of application source code or production database records.
- Justification: This role monitors threats and hardens the system but is restricted from touching the "money" or the "code" to ensure a separation between security oversight and system operations.

Operation Manager

- Allowed: Access to high-level transaction dashboards. Ability to flag accounts for fraud. Review and approve administrative refunds.
- Denied: Access to cloud infrastructure consoles (AWS/Azure). Ability to modify code repositories or network configurations.
- Justification: This role manages the business logic of the FinTech app. They need to see transaction statuses but should not have the technical power to change how the infrastructure is built.

Database Administrator

- Allowed: Read/Write access to database schemas, configurations, and performance monitoring tools in the Data Zone. Execute approved backup and restore operations. Query production data for maintenance and troubleshooting purposes.
- Denied: Deploying or modifying application source code. Altering IAM policies, security groups, or network configurations. Exporting bulk customer records outside the Data Zone.
- Justification: Database Administrators require direct access to production databases for schema maintenance, performance tuning, and backup operations, but restricting them from application code and IAM changes enforces segregation of duties. All direct schema or data modifications require peer review and documented approval (Section 6.3), limiting the blast radius if the account is compromised.

App Server (Service Account)

- Allowed: Write transaction records to the database. Fetch temporary credentials from the Key Vault. Communicate with APIs.
- Denied: Interactive login access such as RDP or SSH. Ability to modify its own IAM permissions or delete log files.
- Justification: As a non-human identity, the server is limited to specific API calls necessary for the app to function. If the server is compromised, the attacker cannot escalate privileges to the rest of the cloud environment.

6.3 Authentication and Authorization Flows

- Multifactor Authentication (MFA) is required for all human user accounts to lower the risk of credential theft. To maintain high security, MFA should involve at least two different factors from the options: “something you know,” “something you have,” and

“something you are.” The organization will implement a phishing-resistant process that requires a complex passphrase along with a mobile MFA app, which must include biometric verification to approve login requests.

- Credential rotation is mandated for all service accounts to minimize long-term exposure. All sensitive secrets are managed and automatically rotated every 90 days via a centralized Key Vault Manager. This limits the window of opportunity for misusing compromised keys and eliminates hard-coded credentials by enabling the application to load secrets dynamically at runtime.
- Just-In-Time (JIT) access is implemented for all roles requiring elevated privileges, including Developers, Database Administrators, and Security Engineers. Instead of maintaining permanent administrative rights, these users receive elevated permission only after approval of a request for emergency fixes or incident response. These elevated sessions are time-limited and automatically expire once the task is completed. This approach ensures the environment adheres to the principle of least privilege, reducing the risk of lateral movement if an account is compromised.
- Segregation of Duties is implemented to ensure that no single person has excessive control over the system. This is achieved through peer review and approval workflows enforced across all critical infrastructure changes to ensure accountability and prevent unauthorized modifications. For Developers, all code updates and merges in version control systems, such as Git, must be reviewed and approved by a peer before deployment. Similarly, Database Administrators are prohibited from executing direct schema or data updates without documented review and approval from another administrator. This prevents any individual from self-approving their own workflow,

which protects the integrity of the production environment against both accidental mistakes and deliberate harmful actions.

7. SIEM Monitoring Strategy

A robust Security Information and Event Management (SIEM) strategy is essential for maintaining the visibility required to protect sensitive financial data. By aggregating logs into a centralized platform like Splunk, the FinTech startup can correlate disparate events to identify complex attack patterns in real-time. This proactive approach ensures that the "Detection" phase of the incident response lifecycle is prioritized, reducing the dwell time of potential attackers.

7.1 Data Ingestion Sources

To achieve comprehensive visibility across the cloud and application stacks, the following data sources will be ingested into the SIEM:

- **VPC Flow Logs:** Captures IP traffic entering and leaving network interfaces, essential for detecting unauthorized lateral movement or data exfiltration.
- **CloudTrail and IAM Logs:** Provides a history of API calls and changes to the identity infrastructure, allowing for the auditing of privileged user actions (Kent & Souppaya, 2006).
- **Application Logs (JSON):** Custom logs from the core banking engine that track transaction successes, failures, and high-value transfers.
- **Web Server Logs (Nginx/AWS WAF):** Monitors incoming HTTP requests to identify SQL injection, Cross-Site Scripting (XSS), or volumetric DDoS attacks.

7.2 Detection Use Case 1: Brute Force and Credential Stuffing

- **Description:** This detection monitors for a high volume of failed login attempts followed by a single successful login from the same source IP address within a 20-minute window.
- **Splunk-style Query:**


```
index=auth_logs | stats count(eval(action="failure")) as failures,
count(eval(action="success")) as success by src_ip, user | where failures > 10 AND
success > 0 | table src_ip, user, failures
```
- **Why It Matters:** In FinTech, account takeovers (ATO) are a primary threat. Identifying brute force attempts allows the security team to trigger automated account lockouts or step-up authentication before financial assets are compromised (Kent & Souppaya, 2006).

7.3 Detection Use Case 2: Unauthorized Internal Privilege Escalation

- **Description:** Identifies instances where a non-administrative user account successfully performs an action usually reserved for a "Security-Admin" role, such as modifying IAM policies or creating new users.
- **Splunk-style Query:**


```
index=iam_logs eventName IN (CreateUser, AttachUserPolicy, PutRolePolicy)

| search NOT user_groups="SecurityAdmin"

| table _time, user, eventName, requestParameters.policyArn
```
- **Why It Matters:** This addresses the "Elevation of Privilege" category in the STRIDE model. If a standard developer account suddenly grants itself administrative permissions, it indicates either a compromised internal account or a malicious insider.

7.4 Detection Use Case 3: Abnormal Transaction Volume (Anomalous Activity)

- **Description:** This behavioral detection identifies statistical outliers where a user account initiates an outbound transfer volume that exceeds their historical 30-day baseline by three standard deviations.

- **Splunk-style Query:**

```
index=app_transactions
```

```
| stats sum(amount) as daily_total by user
```

```
| eventstats avg(daily_total) as avg_vol, stdev(daily_total) as std_vol by user
```

```
| where daily_total > (avg_vol + (3 * std_vol))
```

```
| table user, daily_total, avg_vol
```

- **Why It Matters:** Sudden spikes in transaction frequency often signal automated exfiltration or fraudulent "cash-out" schemes. Using statistical deviations reduces false positives while catching genuine anomalies that signature-based tools might miss.

8. Incident Response Plan

This Incident Response Plan outlines the procedures the organization follows when detecting, analyzing, containing, and recovering from security incidents within the FinTech application environment. The plan aligns with NIST SP 800-61 and is tailored to the system architecture described in Section 2.

8.1 Preparation

The organization maintains an established IR process, defined roles, and access to required tools, including the SIEM, log forwarders, IAM audit logs, WAF logs, and VPC flow

logs. All production systems reside in a segmented VPC, and logging is enabled across the Public, Application, and Data Zones. Administrative access requires MFA, and backups are encrypted and tested regularly.

8.2 Identification

Potential incidents are detected through SIEM alerts, WAF events, IAM anomalies, API Gateway throttling, or unusual database access patterns. Analysts validate alerts by correlating logs across zones, confirming user activity, and determining whether the event represents malicious behavior, misconfiguration, or expected activity.

8.3 Containment

Containment actions depend on the affected zone and asset. Typical steps include:

- Disabling or restricting compromised IAM roles or user accounts
- Updating security groups or WAF rules to block malicious traffic
- Rotating secrets in Secrets Manager
- Isolating affected application servers or workloads
- Preserving logs and evidence for analysis

Short-term containment focuses on stopping active harm; long-term containment ensures the attacker cannot regain access.

8.4 Eradication

Eradication removes the root cause of the incident. Actions may include removing unauthorized changes, terminating malicious processes, patching vulnerabilities, resetting credentials, and reviewing lateral movement indicators. Application servers may be redeployed from known-good images to ensure integrity.

8.5 Recovery

Recovery restores normal operations while ensuring the environment is secure. Steps include validating system integrity, restoring data from encrypted backups if necessary, re-enabling accounts after verification, and monitoring affected systems for signs of recurrence. Recovery is complete only when systems meet baseline configuration and security requirements.

8.6 Lessons Learned

Following containment and recovery, the IR team conducts a review to identify gaps in detection, access control, logging, or architectural controls. Improvements may include refining SIEM use cases, updating IAM policies, strengthening WAF rules, enhancing segmentation, or updating runbooks. Lessons learned are documented and incorporated into future training and processes.

8.7 Playbook: Compromised IAM Credential

This playbook details the response to a compromised IAM credential, triggered when the SIEM brute-force detection use case (Section 7.2) alerts on repeated failed logins followed by a successful authentication from an unrecognized source IP.

1. **Detection and Triage:** The on-call Security Engineer validates the alert by correlating auth logs with CloudTrail and IAM logs. If the successful login originated from an anomalous IP, the engineer opens a Severity 1 incident ticket and notifies the IR lead and the affected user's manager.
2. **Containment:** Disable the compromised account, revoke all active sessions and temporary tokens, rotate the user's password and access keys via Secrets Manager, and block the attacker's source IP at the WAF.

- Decision point: If CloudTrail shows the attacker performed privileged actions (e.g., policy changes, Data Zone access), escalate to Severity 0 and engage leadership.
3. **Investigation:** Build a full timeline of the attacker's API calls via CloudTrail. Check VPC Flow Logs for lateral movement, query transaction logs for unauthorized transfers, and identify any backdoor IAM users, keys, or policies created during the compromise window.
 4. **Eradication:** Remove all unauthorized IAM artifacts and revert policy or infrastructure changes. Redeploy any accessed application servers from known-good images. Rotate all secrets the compromised account could reach, regardless of evidence of retrieval.
 5. **Recovery:** Re-enable the account with a new password and verified MFA enrollment. Coordinate with the Operations Manager to reverse any fraudulent transactions and notify affected customers per regulatory obligations. Place the account and attacker IP on heightened SIEM monitoring for 30 days.
 6. **Communication:** Internal -- The IR lead updates leadership at each phase milestone. External -- If customer data was accessed, the compliance team initiates breach notification under applicable regulations (GDPR, CCPA).
 7. **Lessons Learned:** Within five business days, conduct a post-incident review documenting root cause, detection effectiveness, and procedural gaps. Refine SIEM thresholds and update this playbook accordingly.

9. Conclusion

This report has presented a defense-in-depth cybersecurity program for a cloud-hosted FinTech startup. The three-zone VPC architecture provides strict network segmentation and encrypted communications, while the STRIDE threat model and risk register identify realistic

attack scenarios and prioritize mitigations. Least-privilege IAM controls, SIEM detection use cases, and a NIST SP 800-61-aligned incident response plan work together to reduce attacker dwell time and ensure structured recovery from security events.

These components demonstrate that a strong security posture is achievable even for a resource-constrained startup when security is treated as integral to system design. As the organization matures, the framework can be extended with capabilities such as endpoint detection and response, container scanning, and formal certification under SOC 2 or PCI DSS.

References

- Behbehani, D., Rajarajan, M., Komninos, N., & Al-Begain, K. (2022). Detecting Open Banking API Security Threats Using Bayesian Attack Graphs. 2022 14th International Conference on Computational Intelligence and Communication Networks (CICN), 789–796.
<https://ieeexplore.ieee.org/document/10008365>
- Cotton, M., Vegoda, L., & Bonica, R. (2010). Special use IPv4 addresses (RFC 5735). Internet Engineering Task Force. <https://datatracker.ietf.org/doc/html/rfc5735>
- CyberSierra. (n.d.). Regulatory compliance for fintech: A complete guide.
<https://cybersierra.co/blog/regulatory-compliance-for-fintech-a-complete-guide/>
- InnReg. (n.d.). Fintech compliance guide for CEOs and founders.
<https://www.innreg.com/blog/fintech-compliance-guide-for-ceos-and-founders>
- Kent, K., & Souppaya, M. (2006). Guide to Computer Security Log Management (NIST Special Publication 800-92). National Institute of Standards and Technology.
<https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-92.pdf>
- Khan, R., McLaughlin, K., Laverty, D., & Sezer, S. (2017). STRIDE-based Threat Modeling for Cyber-Physical Systems. 2017 IEEE PES Innovative Smart Grid Technologies Conference Europe (ISGT-Europe), 1–6. <https://ieeexplore.ieee.org/document/8260283>
- ManageEngine. (n.d.). Vulnerability management overview: What is vulnerability management?
<https://www.manageengine.com/vulnerability-management/articles/vulnerability-management-overview.html>

Microsoft. (2024). The STRIDE Threat Model. Microsoft Learn. <https://learn.microsoft.com/en-us/azure/security/develop/threat-modeling-tool-threats>

National Institute of Standards and Technology. (2012). Computer security incident handling guide (NIST Special Publication 800-61 Revision 2). U.S. Department of Commerce. <https://doi.org/10.6028/NIST.SP.800-61r2>

N-able. (n.d.). Understanding CVE and CVSS: How to evaluate vulnerabilities and manage risks strategically. <https://www.n-able.com/blog/understanding-cve-cvss-evaluate-vulnerabilities-manage-risks-strategically>

Ponemon Institute. (2022). The state of vulnerability management in DevSecOps. Rezilion.

Sawant, A. (n.d.). Vulnerability Assessment and Penetration Testing [Online course]. Coursera & Northeastern University.

Sawant, A. (n.d.). Incident response and SIEM [Coursera course content]. Northeastern University.

Splunk Inc. (n.d.). What is Splunk? https://www.splunk.com/en_us/blog/learn/what-splunk-does.html

Appendix A – Authoring Credit & AI Statement

Author	Contributions
JR Clark	Information Architecture, Assumptions
Daniel Czajkowski	Introduction, Risk Register, Conclusion
Ian Latta	STRIDE, SIEM
Ziwei Song	IAM, Demo Video

Use of AI Tools

Members of the group used AI tools as optional writing and organizational aids during the development of this project. AI assistance was limited to tasks such as refining wording, improving clarity, generating example phrasing, and helping structure sections. All technical content—including system architecture, threat modeling, risk analysis, IAM design, SIEM use cases, and incident response planning—was created, reviewed, and validated by the group. The final submission reflects the team's own analysis and understanding and complies with Northeastern University's Academic Integrity and Use of AI policy.